Complete Inventory of Completed Work:

Major and Minor Research, Engineering, and Manuscript Contributions

Project: Maintainer Prioritization in npm Supply Chains (EMSE Submission EMSE-S-26-02038)

Authors: Md. Ashikul Islam & Shahriar Hasan

Purpose of This Document

This standalone document provides an exhaustive, granular inventory of **all major and minor work** performed in this research project across all 25 research tasks, datasets, algorithms, empirical validations, and publication packages.
It is structured to give both authors complete visibility into every technical, analytical, and writing activity so that:

1. You can accurately, truthfully, and transparently complete the **CRediT Author Contribution Matrix** (`tasks/author_validation_2026-10-28/templates/actual_contributions.csv`).
2. You understand the exact historical trajectory leading up to the **120-Endpoint Human Audit (Task 1)**.
3. You can verify and defend all methodology, data pipelines, and scientific claims for the journal review process.

Date of Inventory: 30 October 2026
Repository: `hasanshahriar32/npm-supply-chain-research`
Target Journal: Empirical Software Engineering (EMSE), Springer
Prerelease Artifact: https://github.com/hasanshahriar32/npm-supply-chain-research/releases/tag/research-validation-2026-10-28

Contents

1 Executive Summary of Research Scope **2**

2 Major Research and Engineering Work Packages **2**

2.1 1. Mathematical Modeling and Optimization Formulation 2

2.2 2. Algorithmic Implementations and Exhaustive Benchmarking 3

2.3 3. Data Mining, Dependency Graphs, and SQLite Infrastructure 3

2.4 4. Empirical and Real-World Security Validations 3

2.5 5. Manuscript Authoring and Publishing Deliverables 4

2.6 6. Visual Design and Graphic Production 4

2.7 7. Reproducibility, Open Science, and Public Artifacts 5

3 Minor Technical, Editorial, and Administrative Work **6**

4 Mapping Completed Work to CRediT Author Roles **6**

5 How to Complete the Author Contribution Sheet **6**

1 Executive Summary of Research Scope

This repository contains an end-to-end empirical software engineering research project investigating maintainer prioritization in the npm dependency ecosystem. Over 25 distinct research and verification milestones have been executed.

Dimension	Quantitative Scale	Key Deliverables / Artifacts
Dependency Graph	7,158 endpoints; 12,217 accounts	Full transitive npm topology, SQLite databases, bipartite incidence graphs.
Algorithmic Suite	3 core objectives; 6 budgets	Greedy set cover (C), Exact union (H), Direct exclusion heuristic (P), Pareto frontiers.
Benchmarking	228 ablation rows; 288 method runs	38 selection runs, 20 empirical pools, 12 synthetic instances across budgets 1, 3, 5.
Replication Cohort	100 roots; 94 graphs; 1,641 nodes	Bounded prospective fresh acquisition with 4,357 version-edge rows and 1,051 accounts.
Incident Validation	49 security incident dossiers	16 matching graph packages; retrospective proof of phished maintainer *qix* capture.
Manuscripts	2 independent tracks	6-page IEEE conference paper; 34-page Springer EMSE journal manuscript (13 figs, 14 tables).
Human Audit Kit	120 stratified endpoints	Probability sample across 4 source strata, offline evidence browser, paired review sheets.

Table 1: Overall Scope and Quantitative Scale of Research Contributions

2 Major Research and Engineering Work Packages

2.1 1. Mathematical Modeling and Optimization Formulation

- **Formulation of Optimization Objectives:**
  - **Coverage Maximization $C(S)$:** Total package-version and repository reach achieved by protecting maintainer set S.
  - **Additive Scenario Exposure $H(S)$:** Transitive risk mass and downstream blast-radius mitigation.
  - **All-Source Exclusion $P(S)$:** Defense-in-depth metric ensuring all maintainers authorized to publish a package are protected.
- **Quorum and Imperfect Mitigation Extensions (Task 13 & 14):**
  - Formulated generalized k-of-n quorum exclusion $P_k(S)$, modeling multi-signature and consensus maintainer release requirements.
  - Formulated imperfect intervention efficacy $H_\eta(S)$, quantifying realistic partial adherence to security controls (MFA, hardware keys).
  - Mathematical proof and numerical implementation of strict zero-budget boundary conditions.
- **Pareto Optimization and Scalarization (Task 07):**
  - Multi-objective scalarization $\alpha C(S) + (1-\alpha)H(S)$ evaluated across fine-grained grid $\alpha \in [0.0, 1.0]$.
  - Discovery of the $\alpha = 0.50$ sweet spot capturing 70% of maximum coverage while retaining 31.2% of exposure mitigation.
  - Heterogeneous risk weighting H_{sole}, prioritizing single-maintainer critical packages (achieving up to 88.04% coverage).

2.2 2. Algorithmic Implementations and Exhaustive Benchmarking

- **Core Algorithm Pipeline (`scripts/study_structural_interventions.py`):**
  - Implementation of Greedy Set Cover heuristic for coverage.
  - Implementation of Exact Union solver for transitive risk mass.
  - Implementation of Direct Exclusion-Oriented heuristic for multi-maintainer exclusion.
  - Evaluation across 6 standard policy budgets: $B \in \{10, 25, 50, 100, 200, 500\}$.
- **Ablation and Sensitivity Benchmarking (Task 03 & Task 23):**
  - Executed 38 selection runs across 6 budgets (228 metric rows) isolating the impact of reciprocal scoring, candidate caps, and deterministic tie breaking.
  - Evaluated 20 empirical candidate pools and 12 synthetic instances across budgets 1, 3, and 5 (96 settings, 288 method comparisons).
  - Demonstrated that the direct exclusion rule matches 51/60 empirical and 35/36 synthetic restricted optima.
- **Statistical Hypothesis Testing and Monte Carlo Simulations:**
  - Conducted 6,000 random budget simulations across 200 distinct random seeds.
  - Calculated Monte Carlo Standard Errors (MCSE) and non-parametric effect sizes (Cliff's $\delta = 1.0, p < 0.005$).

2.3 3. Data Mining, Dependency Graphs, and SQLite Infrastructure

- **Primary Ecosystem Graph Construction:**
  - Mined transitive dependencies and metadata across 7,158 GitHub-linked npm endpoints and 12,217 maintainer accounts.
  - Resolved strongly connected components (SCCs: 82/68 cycles) and dependency depth frontiers.
- **Dataset Hygiene and Parser Disagreement Resolution (Task 02):**
  - Audited 658 parser disagreements between npm registry manifests and repository `package.json` configurations.
  - Discovered and quantified the 42.4% "version continuity drop" occurring between undated repository HEAD observations and immutable release versions.
- **100% Programmatic SQLite Extraction (Task 12):**
  - Completely purged hardcoded LaTeX tables in the manuscript.
  - Built automated SQLite extraction scripts guaranteeing exact database-to-manuscript data consistency (reconciling maintainer reach for `qix` to exactly 1,476 dependents).
- **Release-Authority Delta Protocol (Task 09):**
  - Extracted 45 temporal release-authority snapshots with 97.8% predecessor metadata availability.
  - Reconstructed SemVer dependency graph with 1,848 edges and 99.89% resolution accuracy.

2.4 4. Empirical and Real-World Security Validations

- **Retrospective Security Incident Validation (Task 04):**
  - Systematically audited 49 documented npm security incidents; mapped 16 matching compromised packages into the study graph.

  - Empirically proved that Exact Union captures the infamous account takeover of maintainer *qix* at **Rank #8** (#5 in version graph), whereas Greedy (>100) and Portfolio (#2,298) completely fail.
  - Discovered and quantified the **85%–92% phantom blast-radius inflation** caused by unpinned transitive analysis on foundational packages like `chalk` and `ansi-styles`.

- **Prospective Fresh Cohort Replication (Task 23):**
  - Executed a clean, prospective data collection from 100 frozen roots: 94 dependency graphs, 1,641 exact nodes, 4,357 version-edge rows, and 1,051 accounts.
  - Re-optimized on 65 common repository endpoints and 1,036 common accounts to confirm that algorithm behavioral trade-offs hold across independent observation epochs.

- **The 120-Endpoint Human Audit Protocol (Task 23 & Current):**
  - Designed a formal stratified probability sampling frame: 120 repositories sampled across 4 source-cardinality strata (30 per stratum) from 7,158 endpoints.
  - Captured 172 registry-request records and 115 commit-pinned snapshots.
  - Engineered the offline `Evidence_Index.html` dossier linking all source texts, manifests, workflows, and lockfiles.

2.5 5. Manuscript Authoring and Publishing Deliverables

- **Track 1: IEEE Conference Paper (6.0 Pages):**
  - Authored complete 6-page IEEE formatted manuscript (`manuscript/build/main_authors.pdf`).
  - Character-neutral surgical polishing eliminating all overfull text boxes.
  - Structured into 4 core figures and concise comparative analysis.

- **Track 2: Springer EMSE Journal Manuscript (34 Pages):**
  - Expanded manuscript into a 34-page comprehensive journal submission (`submission/emse/EMSE_Manuscript.pdf`, Submission ID: `EMSE-S-26-02038`).
  - Formulated 4 focused Research Questions (RQs), empirical ablations, threat wave updates, and comprehensive validity discussions.
  - Created 14 LaTeX data tables and separate 2-page Springer title page.

2.6 6. Visual Design and Graphic Production

- **13 High-Resolution Vector Figures:**
  - Developed programmatic Python rendering pipelines (`scripts/prepare_emse_figures.py`, `scripts/render_review_figures.py`).
  - Generated vector plots for Pareto frontiers, multi-budget metric curves, sensitivity distributions, and benchmark gaps.
  - Restored and integrated the full illustrated architectural overview diagram (`figures/fig1_architecture.pdf`).

- **Visual Compliance and Layout Engineering:**
  - Audited and corrected clipped legends, axis typography, and font embedding across all figures.
  - Ensured complete zero-Type 3 font compliance across all generated PDFs.

2.7 7. Reproducibility, Open Science, and Public Artifacts

- **Public Prerelease on GitHub:**
  - Packaged and published versioned release: https://github.com/hasanshahriar32/npm-supply-chain-research/releases/tag/research-validation-2026-10-28.
  - Built companion distribution ZIP (2.9 MB) with automated checksum verification.
- **Automated Test Suite and Reproduction Pipeline:**
  - Implemented 14 automated unit tests verifying boundary values, deterministic tie handling, and disagreement resolution.
  - Validated isolated execution in a clean sandbox with network access disabled (`reproduce_journal_validation.py`).

3 Minor Technical, Editorial, and Administrative Work

In addition to the major scientific packages, substantial minor and operational work was executed to ensure technical compliance and submission readiness:

1. **Bibliography Modernization:**
   - Comprehensive audit of bibliography recency; added verified 2024–2025 peer-reviewed citations.
   - Corrected publication venues, page numbers, and verified primary DOIs.
2. **Coauthor Metadata Reconciliation:** Updated shared author blocks, title pages, LaTeX configurations, and review tooling to the full official name: **Md. Ashikul Islam**.
3. **Academic Integrity & Similarity Review (Task 18):** Addressed Turnitin similarity feedback by systematically revising phraseology and separating factual definitions from editorial text.
4. **Editorial Guideline Harmonization (Task 25):** Purged internal workflow notes, unified table caption formats, formatted Springer declarations, and generated compliant Editorial Manager metadata.
5. **Author Review Toolchain Development:**
   - Created `validate_reviews.py` for automated syntax, ID immutability, and evidence note checking.
   - Created `build_guide.py` and `build_executive_roadmap.py` compiling publication-quality PDF guides using Tectonic.
   - Created `study_validated_endpoints.py` implementing automated Cohen's κ calculation and disagreement extraction.
6. **Editorial Manager Submission Package Assembly:** Assembled flat source archives (`EMSE_LaTeX_Source.zip`), reference PDFs, questionnaire responses, and the formal correction request statement (`correction_request_draft.txt`).

4 Mapping Completed Work to CRediT Author Roles

The table below maps the completed work to the 14 standardized **CRediT (Contributor Roles Taxonomy)** categories. Use this mapping as your direct blueprint when completing `tasks/author_validation_2026-10-28/templates/actual_contributions.csv`:

5 How to Complete the Author Contribution Sheet

To finalize Task 2:

1. Open `tasks/author_validation_2026-10-28/templates/actual_contributions.csv`.
2. Discuss with your coauthor who led, contributed to, or supported each of the work packages detailed above.
3. Enter concise factual descriptions under each column for **Shahriar Hasan** and **Md. Ashikul Islam**.
4. For roles that were not performed by an author, simply leave the cell blank or write `N/A`.

CRediT Role	Formal Definition	Specific Project Work Done
Conceptualization	Ideas; formulation of overarching research goals.	Formulating the maintainer prioritization trade-off (C vs H vs P), quorum exclusion P_k, and research questions (RQ1–RQ4).
Methodology	Design of methodology; creation of models.	Designing the stratified 120-endpoint sampling frame, scalarization grids, MCSE simulations, and incident validation protocol.
Software	Programming, software development; testing code.	Implementing Greedy, Exact Union, Direct Heuristic solvers, SQLite extraction scripts, unit tests, and the human audit toolchain.
Data Curation	Annotating, producing, and maintaining research data.	Mining 7,158 endpoints, cleaning parser disagreements, extracting release authority deltas, and collecting 100-root fresh cohort.
Validation	Verification of replication and results.	Retrospective incident audit (16 cases, *qix* validation), prospective cohort verification, and the pending 120-repo human audit.
Formal Analysis	Statistical, mathematical, or computational analysis.	Evaluating 228 ablation rows, 288 method comparisons, Cliff's δ calculations, and restricted exact benchmarks.
Investigation	Conducting research and data collection.	Inspecting repository trees, GitHub Actions workflows, lockfile formats, and npm registry responses.
Visualization	Preparation and creation of published figures.	Designing and plotting the 13 vector figures, Pareto curves, blast-radius heatmaps, and system architecture diagram.
Writing – Draft	Preparation and creation of published work.	Drafting the initial conference paper and writing the 34-page EMSE journal manuscript.
Writing – Review	Critical review, commentary, or revision.	Systematic editing, Turnitin similarity revision, bibliography modernization, and response to journal guidelines.
Supervision	Oversight and leadership responsibility.	Mentorship, research direction, methodological quality control, and submission oversight.
Project Admin	Management and coordination of research.	Organizing project milestones, managing GitHub releases, and coordinating Editorial Manager submission.

Table 2: CRediT Role Mapping for Author Contribution Statements